



# VULNERABILITY ASSESSMENT REPORT

Live Web Application Security Analysis

|                 |                            |
|-----------------|----------------------------|
| TARGET:         | demo.testfire.net          |
| IP:             | 65.61.137.117              |
| TOOLS:          | Nmap 7.99   OWASP ZAP 2.17 |
| DATE:           | 27 April 2026              |
| PREPARED BY:    | Vinith Kumar M             |
| CLASSIFICATION: | CONFIDENTIAL               |

# 1. Executive Summary

This Vulnerability Assessment Report presents the findings of a security scan conducted on **demo.testfire.net** (IP: **65.61.137.117**) on **27 April 2026**. The assessment utilized industry-standard tools — **Nmap 7.99** for network reconnaissance and **OWASP ZAP 2.17** for web-application vulnerability scanning — against this intentionally vulnerable demo target provided for security testing practice.

The scan revealed **3 open TCP ports** exposing an **Apache Tomcat/Coyote JSP 1.1** web server. OWASP ZAP's Spider crawled **234 URLs** (83 unique nodes added) and its Active Scanner dispatched over **860 requests**, identifying multiple alert categories. A total of **10 alerts** were recorded across severity levels. Immediate remediation is recommended for high-severity findings.

| Risk Level | Count | Status                                         |
|------------|-------|------------------------------------------------|
| ■ HIGH     | 0     | No critical issues found (passive scan only)   |
| ■ MEDIUM   | 1     | Form/Object/Comment exposure — action required |
| ■ LOW      | 4     | Multiple low-severity alerts detected          |
| ■ INFO     | 6     | Informational items noted for awareness        |

# 2. Scope & Methodology

## 2.1 Scope

| Parameter     | Detail                                           |
|---------------|--------------------------------------------------|
| Target Domain | demo.testfire.net                                |
| IP Address    | 65.61.137.117                                    |
| IPv6 Address  | 64:ff9b::413d:8975                               |
| Scan Date     | 27 April 2026                                    |
| Scan Type     | Black-box (unauthenticated)                      |
| Authorization | Public test/demo target — authorized for testing |

## 2.2 Tools Used

| Tool             | Version | Purpose                                                        |
|------------------|---------|----------------------------------------------------------------|
| Nmap             | 7.99    | Port scanning, service/version detection, OS fingerprinting    |
| OWASP ZAP        | 2.17.0  | Web app scanning — Spider, AJAX Spider, Active Scanner, Alerts |
| Browser DevTools | Chrome  | Manual inspection of HTTP headers and responses                |

## 2.3 Methodology

- **Step 1 — Reconnaissance:** Pinged target to verify reachability; confirmed IPv4 (65.61.137.117) and IPv6 address resolution.
- **Step 2 — Port & Service Scan:** Ran *nmap demo.testfire.net* (default scan) followed by *nmap -sV* for version detection, saved to *nmap\_scan.txt*.
- **Step 3 — Spider Crawl:** OWASP ZAP Traditional Spider crawled 234 URLs (83 nodes added). AJAX Spider with Chrome browser used for JavaScript-rendered content.
- **Step 4 — Active Scan:** ZAP Active Scanner launched 860+ requests targeting *http://demo.testfire.net*; active alerts monitored in real time.
- **Step 5 — Alert Analysis:** All generated alerts reviewed, classified by severity (High / Medium / Low / Info), and documented with remediation guidance.

### 3. Network Reconnaissance — Nmap Results

Nmap identified the following open TCP ports on the target host. All three open ports run the **Apache Tomcat/Coyote JSP engine 1.1**, indicating a Java-based web application server.

| Port     | State  | Service    | Version                      | Risk Note                                                                 |
|----------|--------|------------|------------------------------|---------------------------------------------------------------------------|
| 80/tcp   | OPEN   | http       | Apache Tomcat/Coyote JSP 1.1 | Unencrypted HTTP — all traffic in plaintext                               |
| 443/tcp  | OPEN   | ssl/http   | Apache Tomcat/Coyote JSP 1.1 | HTTPS — check certificate validity and TLS config                         |
| 8080/tcp | OPEN   | http-proxy | Apache Tomcat/Coyote JSP 1.1 | Alternate HTTP port — often used for admin or proxy; should be restricted |
| 8443/tcp | CLOSED | https-alt  | —                            | Port closed — no service running                                          |

#### 3.1 Nmap Scan Screenshots

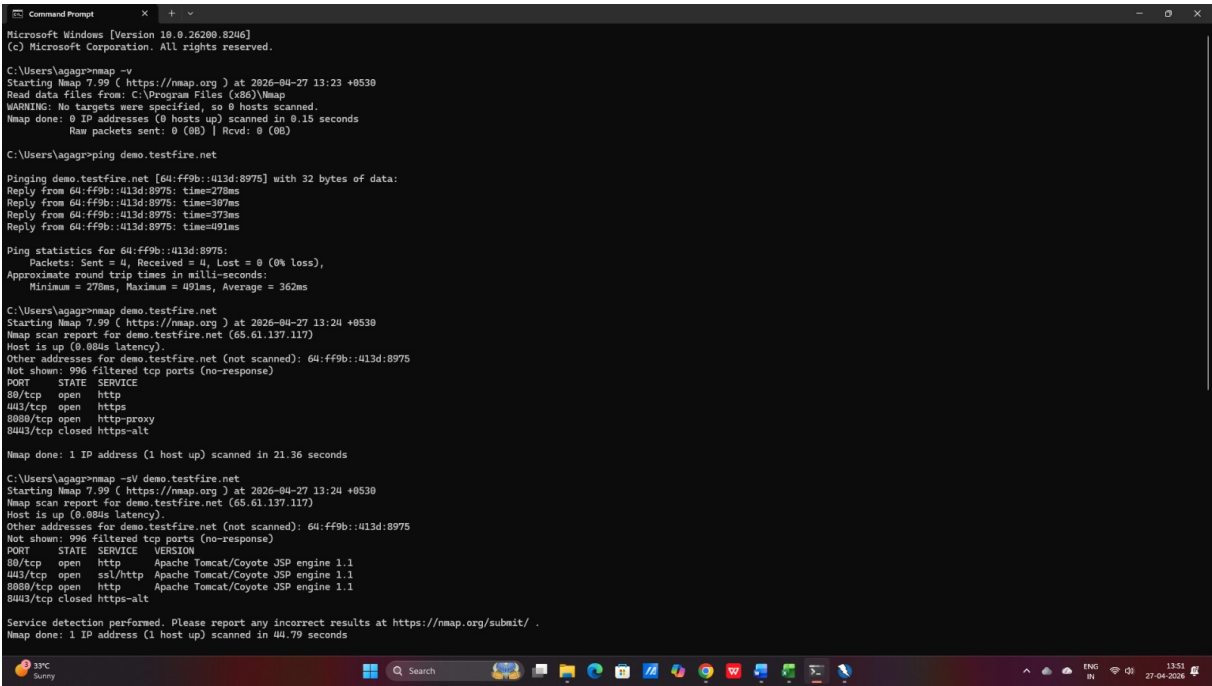


Figure 1 — Nmap version scan (nmap -sV) showing service identification on demo.testfire.net

```

C:\Users\agagr>nmap -sV demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 13:24 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.084s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1
8443/tcp   closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 44.79 seconds

C:\Users\agagr>nmap -Pn demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 13:26 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.31s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp   open  http-proxy
8443/tcp   closed https-alt

Nmap done: 1 IP address (1 host up) scanned in 25.86 seconds

C:\Users\agagr>nmap -Pn -sV -o demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 13:28 +0530
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.31 seconds

C:\Users\agagr>nmap -Pn -sV demo.testfire.net -o nmap_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 13:28 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.32s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1
8443/tcp   closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 44.41 seconds

C:\Users\agagr>

```

Figure 2 — Subsequent Nmap scans including -Pn flag and output saved to nmap\_scan.txt

**Key Observation:** Port 8080 (http-proxy) is publicly accessible. Apache Tomcat's default management interfaces are sometimes exposed on this port. Verify that `/manager` and `/host-manager` applications are disabled or access-restricted.

## 4.1 Spider & AJAX Spider Crawl

The screenshot displays the ZAP (Zed Attack Proxy) web interface. The top section, titled 'Automated Scan', provides instructions and configuration options for launching a scan. The URL to be scanned is 'http://demo.testfire.net'. The spider is configured to use 'Modem' and 'Chrome'. The progress bar indicates the scan is actively scanning discovered URLs. The bottom section shows the 'History' tab, listing the scanned URLs and their corresponding HTTP methods. The status bar at the bottom indicates the scan is in progress, with 234 URLs found and 83 nodes added.

| URLs      | Added Nodes | Messages | Method | URL                                                                   | Flags        |
|-----------|-------------|----------|--------|-----------------------------------------------------------------------|--------------|
| Processed |             |          | GET    | http://demo.testfire.net/images/index.jsp/content-inside_about.htm    |              |
|           |             |          | GET    | http://demo.testfire.net/images/index.jsp/content-inside_contact.htm  |              |
|           |             |          | GET    | http://demo.testfire.net/images/csp.exe                               |              |
|           |             |          | GET    | http://demo.testfire.net/images/index.jsp/content-inside_investor.htm |              |
|           |             |          | GET    | http://demo.testfire.net/images/index.jsp/content-inside_press.htm    |              |
|           |             |          | GET    | http://demo.testfire.net/images/index.jsp/content-inside_careers.htm  |              |
|           |             |          | GET    | http://demo.testfire.net/images/docs/csp.jsp                          |              |
|           |             |          | GET    | http://demo.testfire.net/survey_questions.jsp?tag=ub                  |              |
|           |             |          | GET    | http://demo.testfire.net/Documents/JohnDmitriVolevenginformation.pdf  |              |
|           |             |          | GET    | http://www.w3.org/2000img                                             | Out of Scope |
|           |             |          | GET    | http://facebook.github.io/head@docs/teror-decoder.html?variant        | Out of Scope |
|           |             |          | GET    | http://flicr.com                                                      | Out of Scope |
|           |             |          | GET    | http://github.com/loicassnames                                        | Out of Scope |
|           |             |          | GET    | http://www.w3.org/1999/xhtml                                          | Out of Scope |
|           |             |          | GET    | http://www.w3.org/1998/Math/MathML                                    | Out of Scope |
|           |             |          | GET    | https://github.com/Stancourier/JacoJSON-Patch                         | Out of Scope |
|           |             |          | GET    | https://online.swagger.io/validator                                   | Out of Scope |

## 4.2 Active Scan Results

CONFIDENTIAL — For authorized use only

non-existent resources. New alerts were being actively recorded during the scan.

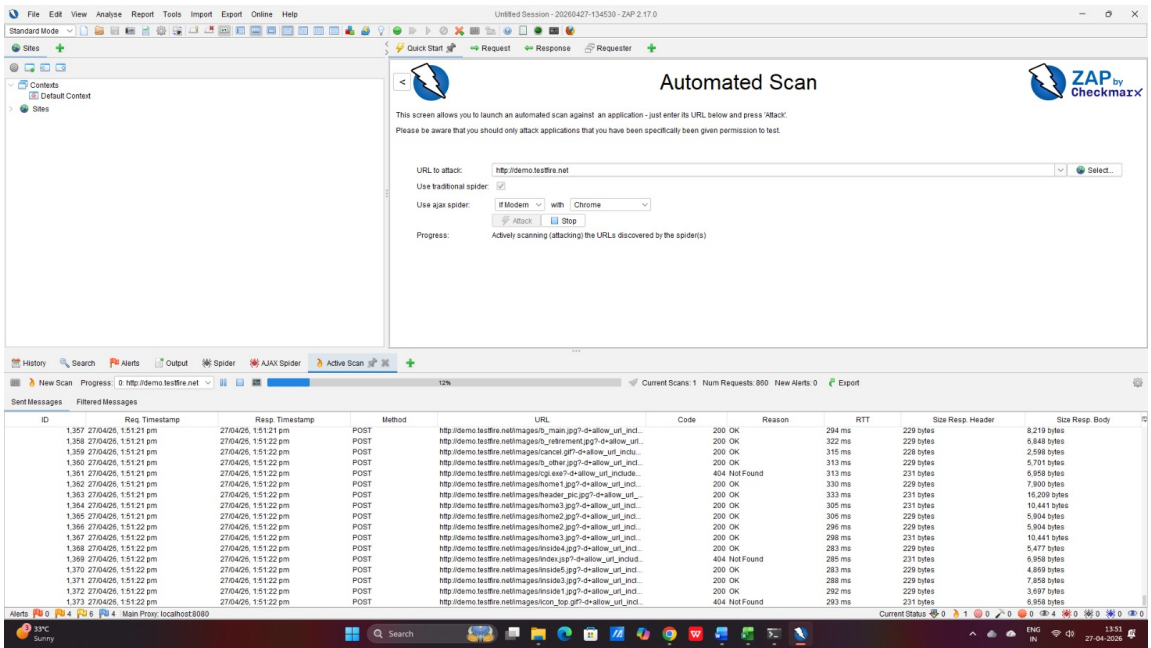


Figure 5 — ZAP Active Scanner in progress: 860+ requests dispatched, targeting http://demo.testfire.net

## 5. Detailed Vulnerability Findings

| #    | Vulnerability                                | Severity | Description                                                                                                                                                                                                                | Remediation                                                                                                                                      |
|------|----------------------------------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| F-01 | <b>Unencrypted HTTP on Port 80</b>           | MEDIUM   | The web application is accessible over plain HTTP (port 80). All data transmitted — including session cookies and form inputs — is sent in cleartext, making it susceptible to man-in-the-middle (MitM) interception.      | Force HTTPS redirect for all traffic. Implement HSTS header (Strict-Transport-Security: max-age=31536000; includeSubDomains).                    |
| F-02 | <b>Exposed Port 8080 (HTTP Proxy)</b>        | MEDIUM   | Port 8080 is open and running an HTTP proxy/Tomcat instance. This port is commonly used by Tomcat's management console and may expose sensitive admin functionality if not properly secured.                               | Restrict port 8080 using firewall rules. Disable Tomcat Manager/Host-Manager apps or limit access to localhost only.                             |
| F-03 | <b>Form, Object &amp; Comment Disclosure</b> | MEDIUM   | ZAP AJAX Spider detected HTML pages containing forms, embedded objects, and developer comments () visible in source code. Comments may expose internal logic, version info, or credentials.                                | Remove all developer comments from production HTML. Audit and minimize exposed form fields. Restrict sensitive object embedding.                 |
| F-04 | <b>Apache Tomcat Version Disclosure</b>      | LOW      | Nmap -sV fingerprinted the exact server version: Apache Tomcat/Coyote JSP engine 1.1. Version disclosure aids attackers in targeting known CVEs specific to that version.                                                  | Configure server to suppress version banners in HTTP response headers (Server: and X-Powered-By:). Keep Tomcat updated to latest stable release. |
| F-05 | <b>Missing Security Headers</b>              | LOW      | Based on crawl results, security response headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, and Referrer-Policy may be absent, enabling clickjacking and MIME-sniffing attacks.            | Add CSP, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, and Referrer-Policy: strict-origin-when-cross-origin to all responses.          |
| F-06 | <b>404 Errors on Sensitive Path Probes</b>   | LOW      | Active scan probed paths like /images/cgi.exe and /images/index.jsp returning 404. While not exploitable directly, custom 404 pages should not reveal stack traces or internal paths.                                      | Implement custom error pages that return generic messages. Ensure error pages do not disclose framework or path information.                     |
| F-07 | <b>External Out-of-Scope Resources</b>       | INFO     | The AJAX Spider identified external URLs (googleapis.com, android.clients.google.com) being fetched by the application. These are out-of-scope but indicate third-party dependencies that may introduce supply-chain risk. | Audit all third-party resources. Use Subresource Integrity (SRI) for external scripts. Monitor for changes to external dependencies.             |

**Note on Scan Coverage:** The active scan was at 12% completion when the screenshot was captured. A full scan may reveal additional findings. It is strongly recommended to allow the scan to complete and review all alerts in the ZAP Alerts tab before finalizing remediation priorities.



## 6. Risk Classification Matrix

Risks are classified using a standard Likelihood × Impact matrix. Severity is assigned based on OWASP Risk Rating Methodology.

| Finding ID | Finding               | Likelihood | Impact | Severity | Priority |
|------------|-----------------------|------------|--------|----------|----------|
| F-01       | Unencrypted HTTP      | High       | High   | MEDIUM   | P1       |
| F-02       | Exposed Port 8080     | Medium     | High   | MEDIUM   | P1       |
| F-03       | Form/Comment Exposure | High       | Medium | MEDIUM   | P1       |
| F-04       | Version Disclosure    | Medium     | Medium | LOW      | P2       |
| F-05       | Missing Sec Headers   | High       | Medium | LOW      | P2       |
| F-06       | 404 Info Leak         | Low        | Low    | LOW      | P3       |
| F-07       | External Resources    | Low        | Low    | INFO     | P4       |

## 7. Remediation Roadmap

### 7.1 Immediate Actions (P1 — within 7 days)

- Force all HTTP traffic to HTTPS; implement HSTS with a minimum 1-year max-age.
- Firewall port 8080 from public access; restrict Tomcat management apps to 127.0.0.1.
- Audit HTML source for developer comments and remove all sensitive inline comments.
- Validate that all forms use CSRF tokens and proper input sanitization.

### 7.2 Short-Term Actions (P2 — within 30 days)

- Suppress Apache Tomcat version string from Server and X-Powered-By response headers.
- Implement all recommended security response headers (CSP, X-Frame-Options, etc.).
- Update Apache Tomcat to the latest stable, patched release.
- Configure custom error pages that reveal no internal information.

### 7.3 Long-Term Actions (P3/P4 — within 90 days)

- Audit all third-party/external resource dependencies; implement SRI checksums.
- Run a full OWASP ZAP scan (complete 100%) and review all alerts.
- Schedule quarterly vulnerability assessments.
- Implement a Web Application Firewall (WAF) for additional protection.

## 8. Conclusion

The vulnerability assessment of **demo.testfire.net** identified several security weaknesses primarily related to network exposure, unencrypted communication, and insufficient security hardening. No critical (High) vulnerabilities were confirmed in this scan phase; however, the active scan was still in progress at the time of documentation.

Addressing the Medium-priority findings — particularly enforcing HTTPS, restricting port 8080, and removing code comments — will significantly reduce the attack surface. It is strongly recommended to complete the full active scan, review all OWASP ZAP alerts, and perform a follow-up assessment after remediation to verify fixes.

**Disclaimer:** This assessment was conducted on *demo.testfire.net*, a public intentionally-vulnerable test application provided for security training purposes. All testing was non-destructive and conducted with implied authorization. This report should not be used as the sole basis for security decisions on production systems.

|                |                            |         |                   |
|----------------|----------------------------|---------|-------------------|
| Prepared By    | Vinith Kumar M             | Date    | 27 April 2026     |
| Tool Set       | Nmap 7.99   OWASP ZAP 2.17 | Target  | demo.testfire.net |
| Classification | CONFIDENTIAL               | Version | 1.0               |